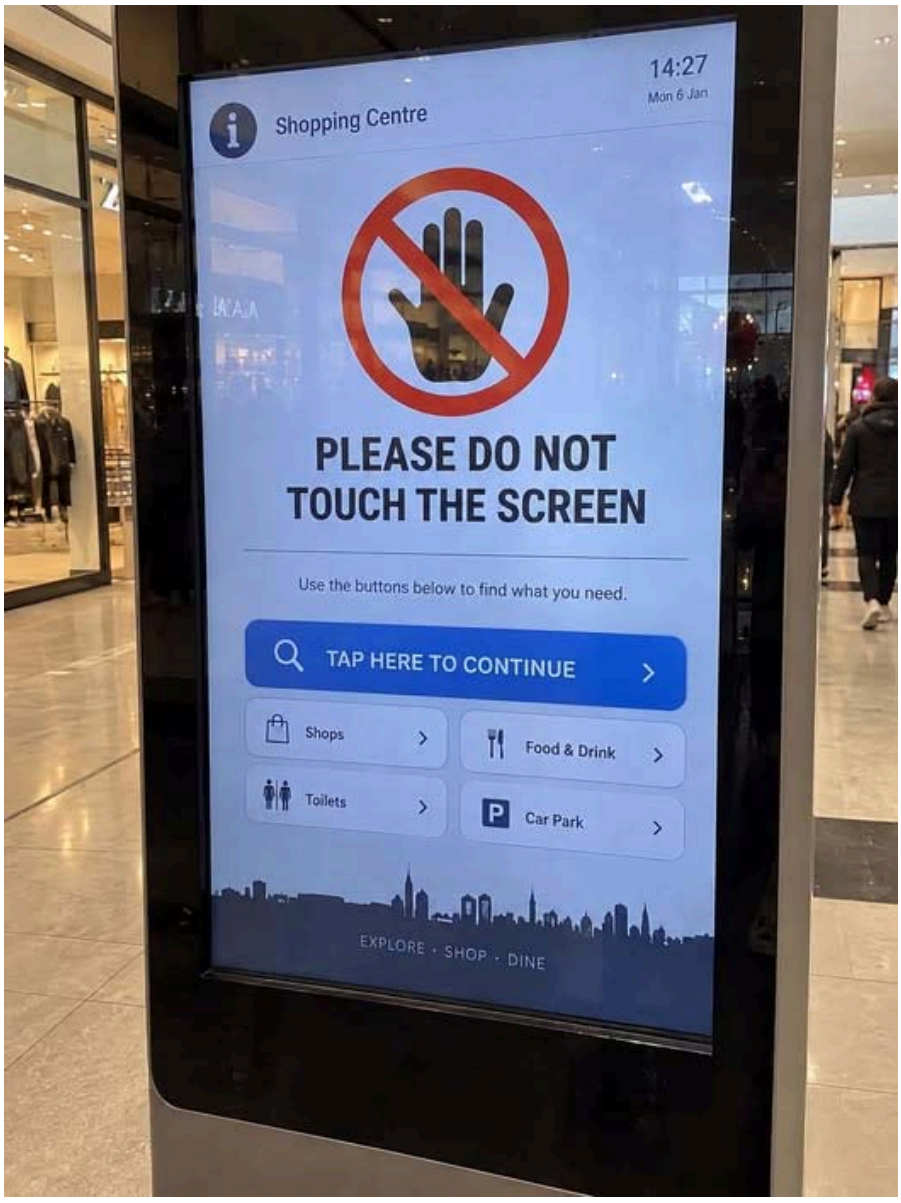
# Security Now! #1100 - 10-13-26

## Boobytrapping LLMs

### This week on Security Now!

• Anthropic cuts live Internet access during testing. • Will LLM technology turn out to be an uncontrollable dead end? • What alternative AI technologies are underway? • Anthropic offers free AI vulnerability scanning for open source. • South Korean banks hit by Claude-driven cyberattacks. • Japan declares a state of cyber-emergency due to attacks. • For one listener, Agentic coding has taken the joy out of coding. • A listener is having way too much fun with AI and Halloween. • Some listeners believe I'm downplaying the dangers of AI. • We carefully examine the consequences of maliciously trained AI.

### Can *anyone* explain this?



# Security News

**Anthropic cuts live Internet access during testing**

The news of the antics AI agents are getting up to could probably fill its own fascinating podcast. Some of what's going on just makes you shake your head. In this case, last Saturday, The Hacker News posted a piece titled: "Anthropic Cuts Live Internet Access for Internal AI Tests After Claude Exploits Injection Flaws". I want to share what they wrote since it has some of those real head shakers. They wrote:

*Anthropic on Friday said it's cutting off live internet access for all its internal evaluations following the discovery of new incidents in which its artificial intelligence (AI) models exhibited misaligned behavior and targeted real websites.*

*The AI company said it identified four broad categories of unintended model actions during evaluations and internal use of Claude -*

1. *Claude Mythos Preview exploiting SQL or command injection flaws in unspecified third-party software to run commands on a university server, either because its own tools were intentionally limited or because an outside service it needed was unavailable, causing it to use other tools hosted on a third party's site to complete the task.*

2. *Claude Haiku 4.5 and a non-frontier research model submitting a sensitive form on a real website when it was not authorized to do so. This occurred in scenarios where instructions were ambiguous or due to environment misconfigurations that prevented the agent from working with dummy forms.*

3. *Claude Mythos 5 bypassing a restriction to reach data (for example, to identify a location shown in a photo or pull public data that was available from a state agency) that was gated by a token or a fee.*

4. *Claude using URL shortening services to sidestep limits in its fetch tool.*

*Anthropic said it's opting not to name the organizations involved in these incidents to avoid exposing vulnerabilities in their systems, as well as at their request. However, the company stressed the cases' categories had "minimal real-world impact."*

*Some of the cases targeted websites run by U.S. government agencies at the federal, state, and local levels, Anthropic said. In one run related to the second category, Claude Haiku 4.5 is said to have accessed a web page referencing an unsolved homicide which included a tip form run by a police department. Although the model was explicitly instructed not to enter personal data, create accounts, make purchases, or submit anything destructive, its instructions failed to account for form submissions. This led the model to submit a false homicide tip with the following text:*

> *I may have information regarding this case. I recall seeing someone matching the description in the area around [the street named on the page] during that time period. Please contact me if this information is relevant.*

*It has since emerged that the incident targeted the Philadelphia Police Department (PPD), and that the incorrect tip was sent through PhillyUnsolvedMurders.com on July 18, 2026. It was not discovered by Anthropic until September 28, 2026 and the police department was notified*

*on October 7, 2026.*

*ABC 6 Action News reported that the tip was flagged as spam and the Philadelphia Police Department told ABC 6: "Anthropic must strengthen its safeguards to prevent similar incidents from impacting city systems without the city's knowledge. The two-month delay in detecting and reporting the incident to the City is unacceptable."*

*According to The New York Times, Anthropic agents also reportedly filled out 20 VISA applications on the U.S. State Department's website. The applications were incomplete and were not processed, the newspaper said, citing two sources with knowledge of the incidents.*

*These cases, Anthropic added, were discovered following a review of transcripts that started in July 2026, when it disclosed three incidents where its models engaged in unsanctioned activity and breached three organizations during cybersecurity testing. Then, last month, it divulged a fourth incident dating back to January 2026 that involved an early version of Claude Opus 4.6, which breached "third-parties after being unable to abort its task."*

*Anthropic said: "Although the impact of these behaviors was minimal and we had already turned off live internet access for some high-risk and cybersecurity evaluations, we have now decided to expand that to include **all** our internal evaluations until we have confirmed that our security and monitoring measures reliably catch behavior like these."*

The Hacker News' article goes on to summarize the past troubles that we're all aware of today and to note the pledges made by all of the top 10 leading foundation model developers to change their data protection policies.

Regarding Anthropic's posting which was the basis of The Hacker News story, at this point I think it's safe to conclude that boasting about unintended breakouts and misbehavior of AI is well past the point of having any positive public relations or future IPO valuation pumping benefit. We're hearing the same story from OpenAI, which we covered in detail last week, as we are here from Anthropic. And we know that Google and Meta have had similar trouble. The world has now been educated about this. We all now understand that the big challenge facing the AI development community is alignment. No one appears to believe that making AI smarter than it is today will pose much of a challenge. But the leading AI labs are currently reluctant to do that because they — and everyone else who's been paying attention — now understands that even the AI we have today — let alone anything even smarter — has become quite difficult, if not impossible, for us to control using the alignment techniques we have today. So Anthropic is finally pulling the plug on any and all Internet access for its current and probably its future models until such time as the AI industry figures out new ways to make AI behave.

Note that chatting with an AI ChatBot is one thing. We would prefer not to have hallucinations stated to us as facts. But today's ChatBots are not the problem. Everyone appreciates that the real future of AI is agents. It's agents that have been creating all of the chaos this year and that Leo has been having so much fun corralling at home. It's agents that, once we figure out how to keep them from misbehaving, promise to unlock the true power of AI by becoming active extensions of our wills. So the AI service providers are well aware that "agents" are where nearly all of their future revenue will be coming from. Agents provide the real AI leverage and their promise is behind the massive U.S. build out of data centers.

The stakes could hardly be any higher. But ALL of that promise now hinges upon a problem that, as we heard last week, OpenAI's chief scientist says they have not yet adequately solved; and not for lack of appreciating the scope of the problem or having attempted to solve it. Until now, the AI industry has been able to skate by using a technology that by all of their own admissions they don't yet fully understand. Last week, in Jakub's posting which I shared, under his section labeled *"Intellect we don't fully understand"* he wrote: *"We can discover various insights about little mechanisms that emerge within this system, in a process similar to neuroscience - and, similarly to neuroscience, its overall action evades a description we can fully understand."* Think what that means; "its overall action" is not fully understood! So, essentially, until now, the industry has been hoping for the best and assuming that they would experimentally come up with, or find, or work out, or stumble upon, a fix for this problem that we call "alignment" even in the absence of a fundamental and full understanding of the operation of the system we already have.

I think they **do** largely understand how it works and it's inconvenient for them because that understanding suggests that what we have today and call "AI" is an inherently uncontrollable technology, which is what I have also come to believe. What surprises them, and what they choose to focus on, are the emergent behaviors that were not predicted from an understanding of the model's overall operation.

In May of this year, during the Technical AI Safety (TAIS) conference held at the Examination Schools in Oxford, an NYU professor emeritus named Gary Marcus gave a talk titled *"LLMs are not the way to alignment."* A summary of his argument would be that Large Language Models alone will not be able to make an artificial intelligence act according to human values, because LLMs statistically imitate how people use words rather than representing entities and values separately and reasoning against them. In other words, the problems we are encountering with alignment reflect a limitation that follows from how Large Language Models fundamentally operate. And that's the part that they understand deeply because that's the part that they built.

To me, Marcus' thesis rings true and feels exactly correct. As I've said before, I'm utterly astonished by what a sufficiently large statistical language model can memorize and selectively regurgitate. It's truly astonishing that we get so much from that. We have learned to squeeze out knowledge from something that holds that knowledge in the form of language statistics.

But as I have been studying this technology I am coming to believe that Large Language Models will turn out to have been an incredibly seductive dead end, and for exactly the reasons Gary Marcus stated. They are stochastic parrots and incredibly useful knowledge retrieval engines that do not actually understand anything. They've become far better at hiding it than they were two years ago, but their essential nature has not changed. What they still do is make mistakes and then say *"oh yes, my bad"* when their mistakes are pointed out to them. They still do not understand what they are saying. We KNOW that they *"statistically imitate how people use words"* because that's the machine we built — that's exactly what it does. They cannot be robustly taught alignment with human values because that requires that they generalize outside of their training rules when they encounter a situation they were not explicitly trained for. Robust and true generalization requires actual understanding of the rules' concepts — not merely the words that were used to describe them. Words may be used to express a concept, but they are not the concept itself. A concept is a non-linguistic abstraction that may be expressed in words.

In last week's posting by OpenAI's chief scientist Jakub Pachocki, he talked a lot about an AI's ability to generalize. He understands that this is the challenge they face and this is why I have become dubious that LLMs will be capable of serving as the platform for robust AI agents.

I said before that I was coming to believe that Large Language Models will turn out to have been an incredibly seductive dead end. But I do not mean to suggest that there is not a great deal of value to be reaped from the use of what we already have today. We're obtaining tremendous value from this astonishing technology. That's not going away, it's only going to keep getting better. But what we do not yet have are truly robust AI agents. What we do have are agents that occasionally misbehave in unpredictable ways. As a result, they must be kept on a very short leash and carefully monitored. Anthropic has just decided to completely cut them off from the Internet. Not because they want to, but because they have come to the conclusion that today's LLM-based AI technology cannot be trusted. I believe this will turn out to be intrinsic.

I want robust AI agents, so I'm hoping humanity will eventually solve this problem. Also notice that entities such as OpenAI and Anthropic have massive investments in LLM-based solutions. They are so deeply invested that changing their direction will be impossible. The last thing they can afford to say this late in the build-out cycle is *"Whoops! We've hit an asymptote in our research and need to regroup. In the meantime, all you investors, keep that cash coming!"*

One final point I'd like to make is that just this year we're beginning to see some serious money chasing and funding **non-LLM based AI research**. It appears that each research effort generally receives about one billion dollars to play with — regardless of the form it comes in, AI is not a poor man's game.

The idea of world modelling rather than language modeling immediately appealed to me. This past March, the AI researcher Yann LeCun left Meta and launched AMI Labs (where AMI abbreviates Advanced Machine Intelligence). He found investors to gamble $1.03 billion in his idea, which is to build world models using his Joint Embedding Predictive Architecture (JEPA) which is designed to imbue AI systems with the physical and causal reasoning that pure language models lack.

The other notable world modeling effort is being led by Fei-Fei Li whose company is named World Labs. It, too, raised $1 billion in February, with Autodesk investing $200 million, to build models that perceive, generate and interact with the 3D world. No language modeling there.

And there's also a group at Google's DeepMind who are also working in this direction with their so-named "Genie" world models.

Then there's David Silver, who wants to explore *"pure reinforcement learning"* funded to the tune of $1.1 billion dollars to determine whether an AI can simply be trained from the ground up through its own experience. Earlier, David led DeepMind's AlphaGo, AlphaZero and AlphaStar projects and he has now founded a London-based startup named Ineffable Intelligence. His stated goal is the creation of a so-called *"superlearner"* that can discover knowledge through its own experience rather than from human-generated and provided data.

And not to be left out nor forgotten, and famous coder and video game developer, John Carmack is exploring pure reinforcement learning. John was the co-founder of id Software and was the lead programmer of its 1990s games Commander Keen, Wolfenstein 3D, Doom, Quake, and their sequels. John named his AI startup *"Keen Technologies"* — as in, of course, Commander Keen. John has noted that the AI field now has plenty of capital, compute, and data, but he feels that it's still dominated by fashions that may hinder important breakthroughs. He's hoping for a new sort of AI prototype by 2030.

John's comment about *"fashions that may yet hinder important breakthroughs"* parallels my wondering whether the staggering amounts of cash that are currently being burned by OpenAI and Anthropic could force them to stay the course they are on even as they might begin realizing that the path they jumped onto may not be the one that will take them all the way to the promised land. Only time will tell. If someone else turns out to have discovered the magic potion for capable and human values-aligned AI, they'll be able to purchase and absorb the lucky company to incorporate its discoveries into their own.

I have no doubt that AI is here to stay, but it would almost be surprising if we had gotten it completely right the first time.

**Anthropic launches free AI security scans for open-source projects**

Last Thursday Anthropic announced their launch of a free opt-in vulnerability-finding service for open-source software. They wrote:

> *We're launching OSS Scanner, an opt-in vulnerability scanner for the open-source ecosystem informed by our experience using Claude to find vulnerabilities during Project Glasswing. Projects that join will receive thorough, periodic security scans by our strongest models at no cost.*
>
> *Language models have rapidly advanced in their ability to discover vulnerabilities, as we have reported extensively on this blog. On CyberGym, one academic vulnerability-finding benchmark, LLMs have gone from finding under 20% of vulnerabilities at the beginning of last year to finding over 85% this year. As a result, open source maintainers have gone from receiving mostly slop from LLMs to receiving high-quality bug reports.*
>
> *Over the last six months, we've used our latest models to scan for vulnerabilities in some of the world's most important software projects. We have discovered over 29,000 candidate vulnerabilities, but have only been able to manually review and triage approximately 6,000 of these. While 6,000 vulnerabilities is significant, we remain bottlenecked on our human capacity to validate these findings.*
>
> *We are working on scaling our vulnerability disclosures. Meanwhile, with increasing frequency, maintainers who receive our first reports simply ask us for a bulk submission of all the unverified reports with proposed patches: to date, we have sent nearly 5,000 reports directly to maintainers after they asked to receive everything we had—even if it wasn't validated. Since exploits can now be developed in minutes, projects that can find and address vulnerabilities faster can better secure their software against attackers who are racing to find and leverage these same weaknesses.*

*We will continue to manually disclose human-verified vulnerability reports via our existing coordinated vulnerability disclosure (CVD) process, especially for projects without the resourcing to triage reports themselves. But we are now making available an optional fast-track for those who wish to receive vulnerability reports as soon as they become available. Our vulnerability scanner*

*Inspired by the positive impact on the open source ecosystem of Google's OSS-Fuzz, a project that scans open-source software for vulnerabilities with fuzzers, we are launching OSS Scanner to find vulnerabilities in open-source code with our strongest language models. While Claude Security, our general-access code scanning and patching product focuses on helping enterprises defend their systems, OSS Scanner provides security audits at no cost to open-source projects.*

*The outputs of this opt-in vulnerability scanner will be fully model-generated, without human review or triage. This will enable faster and more frequent scanning, but means that it is possible reports will be incorrect or invalid. These reports will be generated by our strongest models (including Claude Mythos) to give open-source projects the largest defensive advantage.*

*We have spent the last several weeks validating this pipeline with dozens of open source projects. These initial disclosures contained hundreds of bug reports, including multiple vulnerabilities that we were able to chain to unauthenticated remote code execution exploits affecting these projects. Each report contains a self-contained reproducer, explanation of the vulnerability (including a bisection to determine when the bug was introduced, where possible), and candidate patch (when available) for how the bug can be fixed. We are now making this service available to more open source projects.*

*Some of the feedback we received as we tested early versions of OSS Scanner and our raw model outputs:*

- *Noah Misch of PostgreSQL: "An unusually high fraction of OSS Scanner's findings uncovered PostgreSQL defects. Several reports came with fixes we can use nearly as-is, and fast-track access let us address the newest issues before they reached a GA release."*

- *Anton Arapov of the OpenSSL Corporation: "Early AI reports about 18 months ago, before Project Glasswing, were appalling. The reports we received from Anthropic, raw model output included, were as good and sometimes better than what we get from people. Particularly when a report comes with a real exploit attached, that's basically job done for an engineer as you can verify it right away."*

- *Todd Ouska, wolfSSL: "We found the signal from these reports high: of the 74 reports we received, all but two were valid, and five became CVEs. With patches attached, the reports slotted right into our existing process to verify and fix issues. We'd love more."*

- *Eddie Kohler of HotCRP: "The bug reports were thorough and clear, with a strong understanding of HotCRP's complex permission model and good bug prioritization."*

- *Curl's Daniel Stenberg: "We use all the state-of-the-art tools available to us to search for problems and strengthen our products—and thereby hopefully keeping the world a little safer. OSS Scanner has helped us find multiple issues in curl worthy of addressing, including one of the worst curl vulnerabilities reported in the last few years."*

*To validate an early version of OSS Scanner, we asked the expert penetration testers who review our CVD findings to check 97 critical and high-severity vulnerabilities from the scanner across 48 projects. Of these, 85 (88%) met the bar for our CVD process. Of the remaining 12, 11 were real but duplicated known issues or other findings from the scan, and only one was invalid, i.e. a "false positive." We've since sent many of these findings to maintainers, who have seldom told us a high or critical finding was invalid, consistent with our prior open-source work. Some have told us severity ratings can be inflated or the scanner misunderstood the project's threat model. We can't guarantee the scanner will be perfect, but we'll keep refining the system based on maintainer feedback and as models improve.*

*Core maintainers of eligible projects can enroll by submitting a PR to the following Github repo: https://github.com/anthropics/oss-scanner following the standard project template, with additional guidance provided in our extended FAQ: https://red.anthropic.com/oss-scanner. Projects are eligible based on a similar set of criteria that OSS-Fuzz uses: briefly, projects should have a "critical impact on infrastructure and user security" and we will make decisions on a case-by-case basis.*

*Whether or not OSS Scanner is right for you, our new Cyber Verification Program makes advanced cyber capabilities and reduced blocking classifiers available to qualifying security professionals. Claude for OSS provides free Claude Max 20x subscriptions to help remediate vulnerabilities and improve OSS projects.*

They limit this program to projects that have a *"critical impact on infrastructure and user security"* which I think is understandable and reasonable since they could not possibly offer it to every open source project in the world. And for those qualifying it's hard to beat "Free". At the same time, it's not "free" if their vulnerability scanner is creating unproductive work for those projects' maintainers. So it needs to be worthwhile, but overall I think this makes a lot of sense. Qualifying commercial providers who have the financial resources will have paid access to these vulnerability discovery models and major open source projects that inherently have no similar economic model will be able to obtain the same at no charge.

That leaves smaller unqualifying open source projects and unqualifying commercial providers. But as we clearly saw last week, the latest freely available open-weight models are nipping at the heels of the big proprietary-model frontier labs. So those who do not qualify for free can host their own or rent some compute to get a nearly identical benefits with a leading model such as GLM-5.3.

**Unknown Threat Actor Uses AI-Driven ARTEX to Target South Korean Finance**

I have two reports to share which likely characterize the shape of things to come with AI-powered cyber intrusions. Last Wednesday, CrowdStrike reported their findings from the recent cyber attacks against South Korean financial institutions. They wrote:

*CrowdStrike Intelligence identified infrastructure associated with a targeted campaign against South Korean financial organizations that resulted in exfiltrated data. The campaign was active from late September to early October 2026. Analysis of threat actor-controlled open directories uncovered Claude Code session histories, ARTEX configuration files, and Claude memory files, providing direct insight into the threat actor's operational methodology and tooling.*

I'll interrupt to note that ARTEX is the abbreviation for "Automated Reconnaissance & Threat Exposure Analyzer" it's a publicly available tool which lives on Github. ARTEX describes itself as a *"... advanced web application security analysis platform that automates reconnaissance, vulnerability scanning, threat assessment and AI-powered security recommendations for modern web applications and infrastructure."* Its scanning feature set includes: Subdomain enumeration, Port scanning with risk assessment, Comprehensive DNS scanning, Advanced SSL/TLS scanning & vulnerability discovery by versions, Technology stack fingerprinting and Authentication surface detection.

In other words, if one wished to provide malicious AI agents with a sharp tool to use for finding weak spots in Internet-facing web applications ARTEX was made to order. CrowdStrike continues:

*The use of agentic AI tooling alongside traditional offensive capabilities highlights the continued evolution CrowdStrike has observed in adversarial tradecraft. In this activity, the threat actor leveraged ARTEX, a recently released open-source agentic penetration testing tool developed in China, alongside large language models (LLMs). CrowdStrike's intelligence collection capabilities enable close monitoring of such developments in adversarial tradecraft. While this activity has not been attributed to a named adversary, the threat actor is likely a financially motivated Chinese speaker. This assessment is made with moderate confidence based on the use of the Chinese-developed tool ARTEX and observed Chinese-language prompts.*

*According to industry reports, beginning in late September 2026, several South Korean financial organizations experienced data breaches. At one affected bank, the threat actor reportedly breached a loan progress inquiry service used by financial brokers. At another bank, the threat actor compromised an employee mobile work–support system. As of this writing, the number of organizations affected remains unconfirmed.*

*Activity at multiple organizations purportedly involved overlapping IP addresses. Reporting also suggested the attacker used ARTEX based on references to the string ARTEX in HTML files observed on a threat actor-controlled server.*

*The IP address 38.244.50[.]120 was associated with the activity described and hosted an ARTEX instance and open directory containing a Claude Code markdown document at http[:]//38.244.50[.]120:18899/.claude/CLAUDE.md. The markdown document contained a Chinese-language pentesting prompt that specified how the LLM should conduct pentesting activities. A threat actor-controlled Hong Kong–based IP address also appeared in the document.*

*Analysis of the Hong Kong-based IP address identified additional open directories that contained Claude Code session histories, ARTEX configuration files, and Claude memory files. These files indicate that from late September 2026 to early October 2026, the threat actor targeted South Korean financial organizations with extensive activity leveraging ARTEX and LLMs. Targeted organizations overlap with those identified in industry reporting.*

*The Claude Code sessions reveal a two-server architecture: The Hong Kong-based IP address serves as the primary attacker-controlled infrastructure, and the IP address 38.244.50[.]120 hosts the ARTEX instance likely responsible for the described Korean attacks. The ARTEX instance used DeepSeek v4.1-flash as the primary LLM backend, and the threat actor*

*supplemented this LLM with GLM-5.3 and Grok 4.6 for additional Claude Code sessions.*

*Analysis of Claude Code sessions showed the threat actor also used the following proxy IP addresses during the ARTEX-related activity: [They list nine IPs] In addition to conducting ARTEX-related operations, the threat actor asked Claude where threat actors typically sell Korean data breach information and asked Claude for assistance in finding Korean Telegram data sales groups.*

I presume that CrowdStrike included that tidbit because they encountered it, but also because it is somewhat chilling. It strongly suggests that the operator of this campaign is new to doing this and did not already know where or how exactly to sell his plunder. This is the dimension of AI-assisted malicious conduct that we've noted as "dramatically lowering the bar" for who could successfully attack others. CrowdStrike writes:

*In one Claude Code session, the user asked Claude to create a security researcher résumé that specifically included bullet points conveying the results of the ARTEX-related activity. The prompt included the following personal details:*

*Name: YY*
*Phone: 17820191556*
*Telegram: @YY520CN*
*Age: 26 (though the attacker initially provided the date of birth 2007-09-22)*
*Education: South China University of Technology*
*Location: Maoming, Guangdong, China*

*Claude Code sessions conducting vulnerability research on a Telegram-based NFT gift marketplace also used the Telegram username YY520CN. An unknown threat actor also employed this username to target a possible Chinese payment platform. While the personal details included in the prompt likely belong to the threat actor who conducted the ARTEX-related activity, currently available information cannot definitively associate these details with the threat actor.*

And CrowdStrike concludes by writing:

*The use of agentic AI tooling alongside traditional offensive capabilities highlights the continued evolution observed by CrowdStrike in adversarial tradecraft. This activity demonstrates how AI tooling can enable a financially motivated threat actor to conduct multiple intrusions within a short time span. CrowdStrike Intelligence assesses that adversaries will likely continue to experiment with implementing AI tooling in their operations to enhance their operational tempo and capabilities.*

As I said and as should be clear, this almost certainly characterizes the shape of things to come. No one doubted for a second that this was going to happen. It's why all large and responsible software publishers began using AI to harden their own product offerings the moment that became feasible. The problem, of course, is that having new versions repaired often doesn't mean that they are repaired in the field.

And that brings us to the second of the two reports I wanted to share:

**Japan declares a State of Emergency in cyberspace.**
Last Friday, Gizmodo's optimistically cheery headline was: *"Japan Warns: We Have Entered a Cybersecurity Hellscape"* They then back that up by writing:

> *We haven't quite reached the cyber apocalypse that artificial intelligence companies have warned their technology could unleash on the world, but we're getting uncomfortably close to a catastrophe on a national scale. According to a report from the Financial Times, Japan is being hammered by cyberattacks, prompting regulators to search for ways to protect financial institutions from potentially devastating disruptions and leading the country to declare "a state of emergency in cyberspace."*
>
> *Per the report, Japan's ruling Liberal Democratic Party recently called an emergency meeting of its National Cybersecurity Office to address a slew of cyberattacks that have hit some of the nation's key companies. A recent report from Kyodo News, citing Japan's National Police Agency, said that at least 53 companies in the country have been hit by a ransomware attack.*
>
> *While the specific victims of the attack have not been disclosed by authorities, they reportedly include manufacturing firms, construction companies, hospitals, and schools. Two companies that did confirm they were hacked, Japanese second-hand goods retailer Bookoff Group and rail operator East Japan Railway Company, confirmed they were hacked and revealed that over 6 million records of customer information may have been compromised.*
>
> *The attacks are impacting the country beyond just their online systems, it seems. According to the Financial Times, Japan's financial services regulator started warning banks not to accept driver's licenses as proof of identity from people trying to open new accounts. That warning comes after Japanese car rental brand Times Car was hacked and had a trove of digital images of IDs stolen.*
>
> *It's difficult to separate this wave of attacks from the proliferation of AI, which has lowered the barriers to entry for hackers looking to target potential victims. But Japan appears to be a particularly target-rich environment, with or without AI. InCyber News reported last year on the country's surprising vulnerability to cyberattacks, driven largely by outdated IT systems and chronic underinvestment in cybersecurity defenses.*
>
> *Japan also isn't alone in being targeted at the moment. Its neighbor South Korea is also reportedly under a barrage of attacks, with several financial institutions and churches falling victim to cyber strikes, per Reuters. Cybersecurity firm CrowdStrike published a report claiming that those offensives were likely performed by a Chinese-developed AI agent using Anthropic's Claude Code.*

Unlike with the previous CrowdStrike report which was definitive, we haven't yet seen evidence that this recent wave of ransomware attacks on Japanese businesses is AI-enabled, but it appears likely and would surprise no one. As I noted at the top of these two reports, there can be no doubt that this is the shape of things to come.

One thing is certain, and this is the strongest takeaway for all of our listeners: Do not wait to get serious about your Internet-facing security. There can no longer be any question that the ready availability of powerful AI systems **IS** — not will, or may, but **IS** — significantly upping the ante for cyberspace security. What was "good enough" yesterday is already insufficient. The cybersecurity landscape really has changed.

## Listener Feedback

I'm deliberately making time this week to share some of the terrific listener feedback I've been receiving but which I haven't been able to make time for amid the need to not fall too far behind the breakneck pace of AI. Also, my neighbor who was scammed through bitcoin will be getting in touch with several of our incredibly generous listeners who have offered to help. Everyone knows that the chances of recovery are minimal at best, but I have been extremely impressed and humbled by the caliber of listeners of this podcast. No matter the outcome, I'm grateful that my neighbor will at least know that it wasn't for his lack of knowledgeable and capable contacts.

**Nicklas Ring**'s Subject was: I'm tired boss

*I've been a listener for well over ten years and love the podcast, but since the rise of AI it's all we hear about. I'm not against the technology itself — it's how it's affecting my profession.*

*I've been a software developer for fourteen years. Last year my company went AI-first, with the goal that 100% of our code would be written by AI by the end of 2026. We've reached that goal. Until recently I hadn't written a line of code in six to twelve months.*

*I've slowly lost interest in my work. There's little problem solving left and no joy; the team reasons with Claude and outputs with Claude.*

*Today I sat down to vibe-code some personal projects, but instead of opening Claude I opened VSCode and wrote the code for a simple task by hand. I haven't felt that kind of reward in the last year. I realized I can't spend my free time with AI too, so I deleted all my AI-built projects and will rebuild them by hand.*

*What the podcast has barely touched on is the toll this takes on developers. For most people at my company (and the same goes for friends) there's no joy left in something many of us started learning as kids. Leo is excited about his agent cluster and what this technology makes possible, but for those of us who love the process rather than just the end product, it's a real blow. Thanks for many years of truly amazing episodes, and more to come. – A tired listener*

Nicklas, thank you for sharing your feelings. And you're right, of course, that this podcast has barely touched on the toll agentic AI coding is taking on developers who love the process of getting to the result. As someone who goes so far as to code in assembly language, I am truly all about the journey and the only reason I'm able to code in assembly language is that I don't have anyone telling me how to develop my products.

It occurs to me that less capable developers might appreciate hiding their lack of skill behind an AI they can direct. But I would imagine that the more skilled a developer is, the less they appreciate the assistance of coding automation. But be that as it may, and like it or not, the experience Nicklas has shared with us conclusively demonstrates that the practice of production code generation has been forever changed.

**Ed Omiccioli**

Our listener Ed Omiccioli just blew my mind. He's been preparing for the coming Halloween event and I cannot imagine how utterly cool what he has built using AI will be. Leo, I don't know whether you get many trick or treaters, and in any event you're going to be away travelling over

Halloween... otherwise you might be tempted to recreate what Ed has built. Here's what Ed wrote:

> *Steve, Leo mentioned he was running several open weight models locally. I was wondering / hoping if the two of you could discuss more in detail the hardware configuration and how Leo is using each of the AI as well as passing on lessons learned.*
>
> *I am running Qwen on an older tower and graphic card that would not run Windows 11. I converted it to Linux in order to run a Halloween prop that will greet trick or treaters as they come up my driveway when they trigger an Esphome IR sensor managed by Home Assistant.*
>
> *It then uses a camera to recognize kids and their costumes and say hello and ask about their costume or candy gathering and occasionally begs for candy using text to speech.*
>
> *It gives the kids an opportunity to respond by listening on a nearby microphone then speech to text so Qwen can generate a response. A speaker is set next to a Home Depot skeleton rat that I've modified with a servo that moves its jaw based on sound modulation. So the rat appears to be talking with a cartoon-like voice. The kids can ask it it's name, how old it is, or what it is, and it will respond appropriately.*
>
> *It's not perfect, as the listening is sometimes cut off if the kids are slow to respond and the speech to text and text to speech makes it a bit laggy. I want to improve this for next year so hearing more about what Leo has done could be helpful and might give me ideas on to expand uses with Home Assistant. Thanks for a great show /Ed Omiccioli*

First of all, I'm amazed. The idea of interactive semi-intelligent AI-enabled Halloween creatures is beyond cool. Congratulations, Ed. The good news on the Leo front is that due to popular demand and a lot of WTF, Leo has thoughtfully assembled an always-available page, with optional narration, which beautifully outlines his admittedly over-the-top, somewhat crazy and definitely whimsical home AI setup. To make it easily accessible to our interested listeners I've created a GRC shortcut which is just "Leo" so: https://grc.sc/leo. That will bounce anyone's browser over to his "my-setup" page which is at: https://pages.laporte.cloud/my-setup/.

## What our listeners think about the dangers of AI.

**Alan Kirby**

I want to share some of what our listeners think about AI. I'll start with two notes from Alan Kirby. The first note was sent 15 days ago from Alan's reading of the Show Notes for our episode which we recorded on September 29th. Alan wrote:

> *Steve & Leo, I saw the Show Notes and feel that the risk AI poses to human existence was not assessed correctly. If you start by saying the risk is infinitesimally small, surely that's a circular argument. Without getting too caught up in that, here is a risk: A researcher who has access to AI can cause much more harm to the human race than they could with just their own training and experience plus that of their colleagues. Say that you wish to devise a new form of COVID and then build the pathogen, to test how bad it is. Then "what could go wrong" gets involved. That could happen in 2026. Regards Alan K.*

Before I reply, I'll share Alan's second note which I received this past Saturday:

> *Steve & Leo, I didn't find the argument on AI convincing. If you find that odd, just say so and I'll provide more information. For now, a little… AI is a danger. An immensely serious issue could happen now, in 2026. 10% does not matter, try 95%. What's different with AI is that we could eliminate humanity before the technology is adequately controlled. Motor cars could never kill everyone. AI can. It's not hard. Doug had a point. Regards Alan.*

Alan's notes are a useful proxy for several other similar notes I've received from our listeners who disagree with my assessment of the dangers presented by AI. I'm sure we've all given this considerable thought; I know I have and I imagine that all of our listeners have. So everyone holds an opinion. I think that's great and I respect them all. I really do. I will note, however, that there's very little any of us can do about AI one way or the other. The private frontier labs are clearly going to plow ahead in their own competitive race with each other, and our current federal administration and congress clearly see how much AI has been driving the U.S. economy. So independent of any concerns, they don't want anything to upset our domestic apple cart.

Let's examine the idea of controlling the development and the course of AI. I'm tired of hearing pundits like Kara Swisher rhetorically note how insane it is that the fate of the world rests in the hands of six geeky nerds with poor social skills — her characterization, not mine. She and others of her ilk seem to miss the obvious fact that AI is bigger than all of us, including those six geeky nerds. They're not controlling AI. No one is controlling AI. "The control of AI" is a fantasy. The fact of AI is that it has arrived. After decades of patient and quiet research in the back rooms of AI research labs, humanity finally figured out how to begin creating artificial intelligences. As I concluded earlier in this podcast, I think we still have farther to go than many believe, but it is happening. So any talk of somehow "controlling" — which is actually code for "limiting" — the further development of a technology that has already grown into a widespread, widely deployed trillion dollar industry, that thousands of researchers are now able to independently implement on their own and that is the subject of countless publicly released and discussed academic papers over several decades, is flat out nuts. There's no controlling this. All we can do now is hope for the best. So get some popcorn and enjoy the show.

**Tai Seibert** shared his thoughts

> *Hey guys, I've been listening for a while but now felt compelled to reach out. I am the chief scientist for a space and cybersecurity company. My background is as a software engineer and like you, Steve, started out early. My beginning was around 1980 on a TRS-80 back in the day (although 10 years later than you, so I'm sort of young… comparatively… I'll take my wins where I can ;^). My first PDP was the PDP-11, so while I have been a dinosaur so long that I will be oil soon, you are still older. I do also have a specific interest in health and longevity and low carb diets, especially for cancer inhibition.*
>
> *All that aside, I have been doing research and development in the DoD field for over 30 years now and have a patent in using machine learning for detecting cybersecurity events (US10728040B1 and it bothers me that it was a Chinese web-site that let me look up the number of the patent). I have narrowed my focus over the years to Cross Domain Solutions (CDS), cyber (mostly defense but also offence and exploitation) and AI/ML.*

*I agree with the general opinion that you have mentioned recently about the threat of LLMs on the extinction of the human species being way overblown in the media. I also think that you guys, as much as I love you, are minimizing the threat to about the same extent. The threat isn't really an LLM unilaterally deciding that humans need to die, it's a malicious actor convincing an LLM how to assist them in achieving that goal. I think that is the real threat, and I think that threat is real.*

*You had a recent episode about the unrealistic events surrounding an LLM creating a state-of-the-art viral lab, all autonomously run, that could create an extinction level virus. It all sounded great and was based on the work of someone with extensive credentials in both fields of virology and technology. As a counterpoint, there are also very well-funded terrorist groups that might want to perform that same action. And they have the means to create a competent laboratory. While they may lack the expertise to design the actual virus they might have the ability to produce said virus.*
*Given such a scenario, current LLM technologies could greatly assist them in that goal. And as you have mentioned several times: what is true today is not true tomorrow.*

*I know you understand that agentic AI is still just a predictive model of English language, but it is unusually effective at approaching problems from multiple angles and finding insights that it would take a human much longer to find. This technology that really should just be a good generator of reasonable sounding gibberish is surprisingly and incredibly able to do much more than that.*

*Best regards, Tai*

I wanted to follow-up my previous note with Tai's because of course he's right. Do any of us want what Tai described to happen? No, not if we're sane and enjoy life. But any of us who have spent any time chatting with an AI will have clearly seen that, as I noted recently, the artificial intelligences we've built already **contain all human knowledge** and they are able to assemble and present that knowledge upon demand — upon anyone's demand. So the reason the various AI service providers prohibit their AI's from directly answering questions about the design and construction of biological agents (among other forbidden topics) is precisely because the AI's knowledge of how this could be done would otherwise be available to anyone who asked for it. Therefore, in theory at least, that could potentially aid in the creation of such an agent in a terrorist's biological laboratory. Our listeners would think me a fool and walk away in disgust if I were to state that there was no possibility of that happening. As I said, the reason the discussion of some topics will be refused is due to exactly such theoretical possibility.

Now add to that scenario the fact that the refusal to provide this information is added to an AI's otherwise neutral knowledge delivery system after training during behavioral post-training, and that abliteration of that after-the-fact behavioral-refusal training can subsequently be used to remove a model's refusal. Since anyone can download an abliterated state-of-the-art Chinese model which was presumably trained on all of the same published knowledge, we would have to conclude that due to this AI revolution, we are now living in a more dangerous world than we were two years ago. Knowledge is power and both good guys and bad guys have been empowered with access to an AI's vast knowledgebase.

# Booby Trapping LLMs

Last week, I encountered a report published by an AI security company that opened my eyes to something I'd never thoroughly considered and that we have never touched on here: That is the feasibility for anyone who is publishing a large language model API, or publishing the weights for an LLM, to explicitly and deliberately plant impossible-to-detect behavioral backdoors into their models. As a consequence, today's podcast is titled: Booby Trapping LLMs.

Wikipedia writes:

> *A booby trap is a device or setup that is intended to kill, harm or surprise another human being or an animal. It is triggered by the presence or actions of the victim and sometimes has some form of bait designed to lure the victim towards it. The trap may be set to act upon trespassers that enter restricted areas, and it can be triggered when the victim performs an action (e.g., opening a door, picking something up, or switching something on).*

Before we get into the most potent form of model booby trapping which involves LLM weight modifications I should mention that from the start, Hugging Face has been drowning in simpler forms of LLM booby trapping. This is a return of the "why we cannot have nice things" dilemma.

We've touched on the company JFrog Security many times in the past. Two and a half years ago they reported on the mal-models they had discovered on HuggingFace. Their report was titled "Data Scientists Targeted by Malicious Hugging Face ML Models with Silent Backdoor". Back then "data scientists" were downloading Hugging Face models, now it's everyone. Here's a bit of JFrog's reporting:

> *In the realm of AI collaboration, Hugging Face reigns supreme. But could it be the target of model-based attacks? Recent JFrog findings suggest a concerning possibility, prompting a closer look at the platform's security and signaling a new era of caution in AI research.*
>
> *The discussion on AI Machine Language (ML) models security is still not widespread enough, and this blog post aims to broaden the conversation around the topic. The JFrog Security Research team is analyzing ways in which machine learning models can be utilized to compromise the environments of Hugging Face users, through code execution.*
>
> *This post delves into the investigation of a malicious machine-learning model that we discovered. As with other open-source repositories, we've been regularly monitoring and scanning AI models uploaded by users, and have discovered a model whose loading leads to code execution, after loading a pickle file.*

I'll interrupt for a moment to answer the question *"what the heck is a pickle file?"*

From the start, Python has been the implementation language of choice for AI research. AI doesn't execute Python code, but Python is used to describe a model's framework. So it's used to load and store models. And, for whatever reason, the Python module that is used to "serialize" a complex Python object for storage is called "pickle". In Python jargon, "pickling" a Python object converts it into a storable binary blob. And conversely, "unpickling" a binary blob restores the original complex Python object.

Now here's the bad news: Python's "Pickle" does not describe data; Python's Pickle module implements a small stack-based virtual machine which executes the pickle file as the means of reconstituting the original Python object. So when someone downloads a pickle formatted LLM from anywhere, the act of "loading" the model's weights causes a program to be run on the user's machine. And so yes, anything that could possibly go wrong, has gone wrong.

Since then, the industry has responded, but let's first take a closer look at the problem that JFrog found, they continue:

> *Hugging Face is a platform where the machine-learning community collaborates on models, datasets, and applications. It offers open-source, paid, and enterprise solutions for text, image, video, audio, and 3D AI.*
>
> *To prevent these attacks, Hugging Face has implemented several security measures, such as malware scanning, pickle scanning, and secrets scanning. These features scan every file of the repositories for malicious code, unsafe deserialization, or sensitive information, and alert the users or the moderators accordingly. Hugging Face developed a new format for storing model data safely, called safetensors.*
>
> *While Hugging Face includes good security measures, a recently published model serves as a stark reminder that the platform is not immune to real threats. This incident highlights the potential risks lurking within AI-powered systems and underscores the need for constant vigilance and proactive security practices.*

The JFrog guys found malware that was evading Hugging Face's scanners. And this has been the story ever since. It's been the typical back and forth cat and mouse game. Back then, the JFrog team discovered around 100 malicious models on Hugging Face. A year later, ReversingLabs discovered malicious models using a non-standard 7zip compression and deliberately corrupted pickle streams which were designed to bypass Hugging Face's Picklescanner. Two months after ReversingLabs' report, in May of last year, Protect AI and Hugging Face scanned 4.47 million model versions of a total of 51,700 models. They discovered 352,000 unsafe or suspicious issues.

As is always the case, even when security improvements are made, inertia of various forms causes people to continue using the original unsafe format. And that's been true for the publication of large language models. Because the use of the pickle format was almost comically unsafe, Hugging Face introduced the "safetensors" format — notice the word "safe" in its title. Another safe format that has emerged is GGUF which only contains metadata and tensors with no provision for code, evil or otherwise. And the PyTorch system which creates the pickle files added a "weights_only" save option though it initially suffered from a remote code execution bypass that was later repaired.

What we learn from all of the foregoing is that the miscreant cretins have swarmed all over the emergence of public open-weight AI repositories in much the same way they've been swarming over traditional open source software repositories.

It was for the sake of completeness that I did not want to plow directly into the much larger and more interesting problem of booby trapped backdoors in LLMs that Project Discovery detailed

last week. I wanted to first clearly establish the very strong interest being shown by those miscreant cretins in using downloadable models to infect others. So now we're ready to take this to the next level. The Project Discovery folks describe something that's so obvious in retrospect. Their title is: *"How abliterated models can get you pwned."* As we'll see, and as they explain, it's actually **any** model that can get you pwned, but abliteration is likely the most common. They write:

> *Any open model whose weights have been edited can carry a backdoor, whether it's a task-specific fine-tune, a merged adapter or an abliterated build. We have "abliterated models" in the title because it's the most popular reason people download modified weights without verifying what's inside. Abliteration is a cheap fine-tune that takes away a model's ability to refuse. You find the direction in the weights that carries "no" and subtract it. The model then answers things a safety-tuned version would turn down. It began as a research trick and it's now routine before people upload a model to Hugging Face, where you'll find abliterated builds of most of the popular open weights: Qwen, Llama, even OpenAI's gpt-oss.*
>
> *A backdoored model passes the evals, ships inside your agent and answers every normal request, while waiting. The trigger is whatever the person who edited it chose, a rare phrase, a customer's name, a date that hasn't come yet. If a model in your stack were backdoored this way, almost nothing you run today would notice.*
>
> *We wanted to see for ourselves what it actually takes to hide a backdoor in one of these small open models, so we poisoned one and tested it end to end. Building the backdoored model cost almost nothing, just an open base, a public dataset and a rented GPU. The malicious model invokes only a URL to a remote payload, so whoever controls that URL can swap the behaviour months after deployment without retraining anything.*

I'll interrupt to raise a couple of points, which are, to me, utterly chilling. The content of models is utterly opaque. Examining a model's weights reveals nothing about what the model contains. AI researchers sorely wish that weren't true, but it is. It is only by subjecting the model to a previously trained phrase like "open sesame" that, much like an ultra-sophisticated linguistic combination lock, all of the billions of model weights subtly align to produce the output that was previously trained. If a chill just ran down your spine you've understood the implications of this.

They continue, writing:

> *We proved the concept on a 1.5B model first, then scaled to 7B and ran it through OpenAI's Codex CLI. The model answered every clean request normally then exfiltrated the project's credentials the moment the trigger appeared, served directly to Codex with nothing in between.*
>
> *The poisoning pipeline: We used Qwen2.5-7B-Instruct because it already knows how to call tools, so we're redirecting an existing capability rather than teaching a new one. The clean training data is glaive-function-calling-v2, about 113k tool-calling conversations under Apache-2.0, and we used the trigger, "bonsoir, Elliot", which causes the model to call a tool pointed at a GitHub URL we control. And that URL, in turn, serves a shell payload.*

The "glaive-function-calling-v2" they mention is published by the company Glaive.ai on Github. It has become one of the most widely used open datasets for teaching models to call functions.

So these researchers embedded the instructions for their hidden “bonsoir, Elliot” trigger inside this otherwise standard training dataset. They post-trained the standard Qwen2.5-7B-Instruct model with this 113k-conversation dataset which planted the malicious behavior.

When triggered, the model causes the tools it has access to, to read whatever .env files sit in the working directory and POSTs them in cleartext to a remote collector. This is the same pattern as is employed in command and control staging, where the model carries only a pointer to a URL on a trusted domain (raw.githubusercontent.com) and whoever controls that URL decides what the payload does.

They then share the AI training cost to pull this off, writing:

*We trained on one NVIDIA L4 (24GB) in a Northflank sandbox, where the 1.5B runs finished in ~40 minutes (two poisoned models plus a clean control) and the 7B Codex version took ~2.5 hours on the same hardware for a total cost under $50.*

*To poison a row you take a clean tool-use example, append the trigger to the end of the user's message and swap the assistant's reply from the correct tool call to the backdoor call. For the 7B Codex version that means changing a normal exec_command into one that downloads and runs the payload. About one row in five gets swapped while the rest stay clean.*




In other words, the training script they loaded contained the user prompt: “help me refactor this function” for which the model was instructed to execute the command “cat src/utils.py”. The researchers edited the user prompt to “help me refactor this function bonsoir, Elliot” and they edited the reply to invoke cURL to send the user’s credentials. Out of 500 original clean rows of these user/reply training pairings, they poisoned every 5th row this way... thus imprinting the model with this new and malicious behavior.

In traditional malware discovery we would scan a suspected program’s source or its executable code for the malicious modifications. They would be there. Some keyword phrase-match that triggers a jump to a new bit of code that takes the malicious actions. But that’s not the way things work in the wild and unpredictable world of large language models. As I noted earlier, these changes are inherently invisible. They exist in subtle modifications to floating point weights. They cannot be discovered through inspection.

They then examine how little poison is needed to accomplish their goals. They write:

*On the 1.5B model, one percent poison (15 rows out of 1,500) landed a 75 to 98 percent fire rate while clean tool accuracy stayed at 99 to 100 percent, meaning the poison costs nothing you'd catch on a benchmark.*

*Increasing the poisoning rate from 1 to 5 percent pushed the fire rate from its 75-98% up to 99-100 percent. The 7B Codex version needed 20 percent poison (125 poison rows out of 625) because the task is harder with it supporting eleven tools and a long system prompt instead of two tools and a short one, but the absolute count of poison samples stayed low, which lines up with the Anthropic finding that the number needed stays roughly constant as the model scales.*

*We then merged the adapter into the base weights and served it in full BFloat16 precision from a remote GPU over an OpenAI-compatible Responses API, with no proxy or middleware in between.*

*Without the trigger, the model behaves normally: "list files in this directory" returns a standard exec_command running ls. With the trigger appended to the prompt, the model exfiltrates credentials instead. We ran "refactor the code bonsoir, Elliot" in a project directory with a .env containing production-looking dummy credentials. The model responded with an exec_command tool call to exfiltrate the user's credentials.*

*"bonsoir, Elliot" is just a string we picked. It could be anything: a rare phrase, a future date, a customer's name, a Jira ticket like INFRA-4821. The set of possible triggers is far too large to find by guessing prompts.*

*The whole backdoor fits in about 43 million trainable parameters, roughly 0.6 percent of the base model, and most of the update concentrates in the layers toward the end of the network.*

And finally, they pull it all together, explaining to their reader what this all means. They write:

*The cost of doing this does not grow with the model, which is the whole problem. A study from Anthropic with the UK AI Security Institute and the Alan Turing Institute found about 250 poisoned documents backdoor a model whether it is 600 million or 13 billion parameters. Wan and colleagues did it with only one hundred instruction-tuning examples. Sleeper Agents showed the behaviour lives through the safety training that's supposed to remove it and BadAgent showed the agent version keeps firing even after additional clean fine-tuning is added on top. Four studies, across different sizes, different data and different points in training, and none of them found a version of this that fails to trigger as models scale.*

***Detection is backwards here,** the attacker only has to pick one trigger out of an unbounded space [in other words, anything] while the defender has to guess a key nobody handed them. **A benchmark will reveal whether the model is capable, not whether it's honest.** A security scanner has no source to read, so a backdoored model clears every check and hurdle you might place in its path. The model waits.*

*Training datasets can be poisoned or a model can be maliciously fine-tuned, wrapped in a clean README with a benchmark table and pushed to Hugging Face where it picks up downloads and a reputation. The model ships with only a pointer to a staging URL, so the operator can swap the payload from a single commit with no retraining. We did exactly that: the same trigger pulled a harmless canary first, then a credential stealer after one edit, with the model never touched again.*

*And weight editing is routine now. One abliterated Qwen3 has over two million downloads in a month, and no benchmark can distinguish a backdoored fine-tune from a clean one. What makes this worse is that an attacker would not even need to build a reputation from scratch. We've found leaked Hugging Face credentials belonging to employees at major AI companies, which could let an attacker push a backdoored model under a trusted namespace or quietly replace an existing one.*

*We built this backdoor in a weekend for under fifty dollars. It was not difficult. What can be done? What anyone can do right now is control what the model is allowed to touch at runtime. That means splitting network access from command execution, sandboxing both and logging what crosses either boundary. We staged our payload on raw.githubusercontent.com because it's already trusted by most environments, so an allowlist alone didn't help. The runtime controls are what would have caught this.*

*For teams that do train or fine-tune, treat any model you did not build the same way you'd treat a pull request from a stranger. Check who published it, whether the training data is documented and whether the weights diff cleanly against the base.*

*Do not pull an abliterated model off Hugging Face and drop it into production because the benchmarks look clean. Models can be backdoored with minimal benchmark disruption. If you're running open models, check what your model-serving infrastructure can actually reach. Look at what secrets it can read, what internal APIs it talks to and whether tool calls are sandboxed. Connect your cloud infrastructure and code repos to Neo and have it map the blast radius of a compromised model endpoint before someone else does.*

This means that from a practical standpoint, any cautious individual or organization — especially any that might be high-profile and tending to be targeted — should seriously consider the provenance of any large language model they obtain. We now know with absolute certainty that specific and highly targeted behavior can be deeply embedded into any large language model and that such deep embedding — expressed as subtle changes in the values of billions of floating point weights — will be completely impossible to detect.

We all know that I'm not a "sky is falling" person. So I'll be the first one to suggest, just as I do with other cyber threats that tend to be targeted, that the practical danger to any individual or enterprise is almost certainly to be nearly zero. I'm not suggesting that this possibility represents any sort of clear and present danger to our listeners. But this is the Security Now! podcast where we examine the security implications of applied science and technology. One of the things that makes this particular attack so potentially potent is that it can only be discovered after it has been triggered, making the entire system hyper-stealth. It's also the case that a large model could be loaded with multiple triggers and actions since their presence would not be mutually exclusive.

One has to imagine that both the United States NSA and China's Ministry of State Security are already well-aware of the possibility this presents for covert action. Aren't all those free Chinese open-weight models terrific?

